

2025

7η Εργασία – Ασφάλεια Web-Εφαρμογών.



ΚΟΥΜΝΤΕΑΣ ΒΑΣΙΛΗΣ

ΑΜ:1083637

1/4/2025

Εργασία

1. Κατεβάζουμε το λογισμικό Apache HTTP web server στην εικονική μηχανή στο Azure με την εντολή `sudo apt install apache2`.
2. Λόγω περιπλοκών, θα χρησιμοποιήσω απλά κώδικα HTML για την διαμόρφωση της ιστοσελίδας. Αυτόν τον κώδικα θα τον προσθέσουμε στο αρχείο `/var/www/html/index.html`.

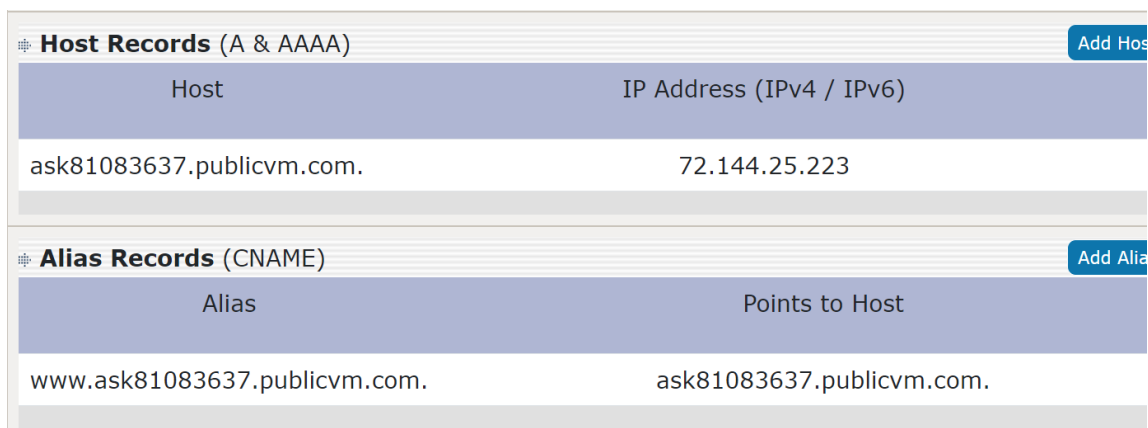


```
GNU nano 5.4 /var/www/html/index.html
!DOCTYPE html>
<html lang="el">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title> ^f ^c ^c 8</title>
  <style>
    body {
      font-family: Arial, sans-serif;
      text-align: center;
      background-color: #f0f0f0;
      margin: 0;
      padding: 0;
    }
    h1 {
      font-size: 2em;
      color: #333;
      margin-top: 20px;
    }
    h2 {
      font-size: 1.5em;
      color: #555;
      margin: 10px 0 30px 0;
    }
    .ascii-art {
      font-family: monospace;
    }
  </style>

```

Εικόνα 1.

3. Μέσω του www.dnsexit.com, εκδίδουμε ένα FQDN. Στην συγκεκριμένη περίπτωση το domain μας θα είναι το ask81083637.publicvm.com, το οποίο ρυθμίζουμε (στο dnsexit) να κοιτάει στην IP της μηχανής μας.



Host Records (A & AAAA)		Add Host
Host	IP Address (IPv4 / IPv6)	
ask81083637.publicvm.com.	72.144.25.223	
Alias Records (CNAME)		Add Alias
Alias	Points to Host	
www.ask81083637.publicvm.com.	ask81083637.publicvm.com.	

Εικόνα 2.

Από την ίδια σελίδα θα εκδώσουμε και ένα certificate από τον οργανισμό Let's Encrypt. Το FQDN και το certificate τώρα, πρέπει να τα εισάγουμε στον web-server μας, κάνοντας τις παρακάτω αλλαγές στα αρχεία:

- `/etc/apache2/sites-enabled/000-default.conf`:

```
GNU nano 5.4 /etc/apache2/sites-enabled/000-default.conf
<VirtualHost *:80>
    # The ServerName directive sets the request scheme, hostname and port that
    # the server uses to identify itself. This is used when creating
    # redirection URLs. In the context of virtual hosts, the ServerName
    # specifies what hostname must appear in the request's Host: header to
    # match this virtual host. For the default virtual host (this file) this
    # value is not decisive as it is used as a last resort host regardless.
    # However, you must set it for any further virtual host explicitly.
    ServerName ask81083637.publicvm.com
    ServerAlias www.ask81083637.publicvm.com

    ServerAdmin webmaster@localhost
    DocumentRoot /var/www/html

    # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
    # error, crit, alert, emerg.
    # It is also possible to configure the loglevel for particular
    # modules, e.g.
```

Εικόνα 2.

- /etc/apache2/sites-enabled/default-ssl.conf:

```
GNU nano 5.4 /etc/apache2/sites-enabled/default-ssl.conf
<IfModule mod_ssl.c>
    <VirtualHost _default_:443>
        ServerAdmin webmaster@localhost

        DocumentRoot /var/www/html

        # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
        # error, crit, alert, emerg.
        # It is also possible to configure the loglevel for particular
        # modules, e.g.
        #LogLevel info ssl:warn

        ErrorLog ${APACHE_LOG_DIR}/error.log
        CustomLog ${APACHE_LOG_DIR}/access.log combined

        # For most configuration files from conf-available/, which are
        # enabled or disabled at a global level, it is possible to
        # include a line for only one particular virtual host. For example the
        # following line enables the CGI configuration for this host only
        # after it has been globally disabled with "a2disconf".
        #Include conf-available/serve-cgi-bin.conf

        # SSL Engine Switch:
        # Enable/Disable SSL for this virtual host.
        SSLEngine on

        # A self-signed (snakeoil) certificate can be created by installing
        # the ssl-cert package. See
        # /usr/share/doc/apache2/README.Debian.gz for more info.
        # If both key and certificate are stored in the same file, only the
        # SSLCertificateFile directive is needed.
        SSLCertificateFile /etc/ssl/certs/ssl-cert-mysite.pem
        SSLCertificateKeyFile /etc/ssl/private/ssl-cert-mysite.key

        # Server Certificate Chain:
```

Εικόνα 4.

Όμως για να σιγουρευτούμε ότι μπορούμε να διαμορφώσουμε τα προαναφερθέντα αρχεία πρέπει, με την χρήση της εντολή `sudo a2ensite conf-file_name_without_conf`, να ενεργοποιήσουμε τα αρχεία `000-default.conf` και `default-ssl.conf`. Επίσης, πρέπει να ενεργοποιήσουμε και το `mod` ονόματι `ssl.conf`, με την εντολή `sudo a2enmod ssl`. Κάνοντας το τελευταίο, ο web-server θα μπορεί να διαβάσει την εντολή `SSLEngine on` που φαίνεται στην εικόνα 4.

Τέλος, πρέπει να δημιουργήσουμε τα αρχεία `ssl-cert-mysite.pem` και `ssl-cert-mysite.key`, που βλέπουμε στην εικόνα 4, με την εντολή `sudo nano /etc/ssl/..` και να βάλουμε μέσα το certificate και το κλειδί από το www.dnsexit.com.

```
GNU nano 5.4 /etc/ssl/private/ssl-cert-mysite.key
-----BEGIN RSA PRIVATE KEY-----
MIIEpAIBAAKCAQEAwsyFBPUFguHjGkq3XanwpVjFNtyK45TTuJSZkt4pDKRnwD7c
q7fOUdA9c8G58ZaA1vCk1CFf22mSA3T10w0rs8NlkQbxAckTqN7fjeVBEpVqHvt5
btFWDb6c/FFH4qB6uhjAPu/p7lzNwjd72BNIV+sAF+8exq1JFCjIUQ4QUd5BomIE
cXvY3e38Vy/89cf81NC0kyU7sCUEmtwQi5IY6rLv0KgvK4R2viDCyP5bvybHbIMT
nmgu14bvh24Ty3naMgaoVi0T0k+tITpA7znN5KH7foal+tUhp8MoQ5pWU7C0k30Ty
```

Εικόνα 5.

```
GNU nano 5.4 /etc/ssl/certs/ssl-cert-mysite.pem
-----BEGIN CERTIFICATE-----
MIIGmzCCBIOgAwIBAgIQbOrDvMyzM1RMbQ90cOnTQDANBgkqhkiG9w0BAQwFADBL
MQswCQYDVQQGEwJBVDEQMA4GA1UEChMHwMvYb1NTTDEqMCgGA1UEAxMhWmVyb1NT
TCBSU0EgRG9tYwluIFNlY3VyZSBTaXRlIENBMB4XDTI0MTIzMTAwMDAwMFoXDTI1
MDMzMTEzNTk1OVowIzEhMB8GA1UEAxMYyXNrODEwODM2MzcucHVibGljdm0uY29t
MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEawsyFBPUFguHjGkq3Xanw
pVjFNtyK45TTuJSZkt4pDKRnwD7cq7fOUdA9c8G58ZaA1vCk1CFf22mSA3T10w0r
```

Εικόνα 6.

4. Το λογισμικό `apache web-server` έρχεται με την επιλογή αυτή ήδη ρυθμισμένη.
5. Προσθέτουμε στο αρχείο `/etc/apache2/sites-enabled/000-default.conf` την γραμμή: `Redirect permanent / https://ask81083637.publicvm.com:`

```
GNU nano 5.4 /etc/apache2/sites-enabled/000-default.conf
<VirtualHost *:80>
    # The ServerName directive sets the request scheme, hostname and port that
    # the server uses to identify itself. This is used when creating
    # redirection URLs. In the context of virtual hosts, the ServerName
    # specifies what hostname must appear in the request's Host: header to
    # match this virtual host. For the default virtual host (this file) this
    # value is not decisive as it is used as a last resort host regardless.
    # However, you must set it for any further virtual host explicitly.
    ServerName ask81083637.publicvm.com
    ServerAlias www.ask81083637.publicvm.com
    Redirect permanent / https://ask81083637.publicvm.com
```

Εικόνα 7.

6. Για να τροποποιήσουμε το firewall ώστε να επιτρέπει πρόσβαση στα ports 443 και 80, πάμε στην ιστοσελίδα του Azure, στις ρυθμίσεις networking της εικονικής μας μηχανής βάζουμε τον επιπλέον κανόνα:

Network security group **up1083637-debian11-nsg** (attached to networkInterface: **up1083637-debian11168**)

Impacts 0 subnets, 1 network interfaces

+

Create port rule

Search rules

Source == all

Destination == all

Protocol == all

Action == all

Priority ↑	Name	Port	Protocol	Source	Destination	Action
Inbound port rules (6)						
100	SSH	22	TCP	Any	Any	Allow
110	AllowAnyCustom53Inbound	53	UDP	Any	Any	Allow
120	AllowAnyCustom80_443Inbound	80,443	TCP	Any	Any	Allow
65000	AllowVnetInBound	Any	Any	VirtualNetwork	VirtualNetwork	Allow
65001	AllowAzureLoadBalancerInBound	Any	Any	AzureLoadBalancer	Any	Allow
65500	DenyAllInBound	Any	Any	Any	Any	Deny

Εικόνα 8.

Διαμόρφωση Παραμέτρων για Προστασία

1. Κάνοντας scan την σελίδα μας με το Mozilla Observatory πριν κάποια διαμόρφωση,βλέπουμε τα παρακάτω τεστ:

Score: 0 / 100			
Scan Time: 3 minutes ago			
Tests Passed: 6 / 10			
Scan another website			
Scan results			
Scoring	CSP analysis	Cookies	Raw server headers
Scan history	Benchmark comparison		
Test	Score	Reason	Recommendation
Content Security Policy (CSP)	-25	Content Security Policy (CSP) header not implemented	Implement one, see MDN's Content Security Policy (CSP) documentation.
Cookies	-	No cookies detected	None
Cross Origin Resource Sharing (CORS)	0	Content is not visible via cross-origin resource sharing (CORS) files or headers.	None
Redirection	0	Initial redirection is to HTTPS on same host, final destination is HTTPS	None
Referrer Policy	-	Referrer-Policy header not implemented.	Set to strict-origin-when-cross-origin, at a minimum.
Strict Transport Security (HSTS)	0	Strict-Transport-Security header set to a minimum of six months (15768000).	Consider preloading: this requires adding the preload and includeSubDomains directives and setting max-age to at least 1 year, and submitting your site to https://hstspreload.org/.
Subresource Integrity	-50	Subresource Integrity (SRI) not implemented, and external scripts are loaded over HTTP or use protocol-relative URLs via src="//...".	Load external scripts over HTTPS, and add SRI to them.
X-Content-Type-Options	-5	X-Content-Type-Options header not implemented.	Set to nosniff.
X-Frame-Options	-20	X-Frame-Options (XFO) header not implemented.	Implement frame-ancestors CSP.
Cross Origin Resource Policy	-	Cross Origin Resource Policy (COP) is not implemented (defaults to cross-origin).	None

Εικόνα 9.

(Να σημειωθεί ότι η εικόνα αυτή βγήκε με άλλο site, διότι το είχα ήδη φτιάξει αυτό που σας έστειλα.)

Για να περάσουμε τα τεστ και να προστατέψουμε την σελίδα μας πρέπει να κάνουμε τις εξής αλλαγές:

-Πρέπει στο αρχείο `/etc/apache2/sites-enabled/000-default.conf` και προσθέτουμε την εντολή `Redirect permanent / https://ask81083637.publicvm.com:`

```
GNU nano 5.4 /etc/apache2/sites-enabled/000-default.conf
<VirtualHost *:80>
    # The ServerName directive sets the request scheme, hostname and port that
    # the server uses to identify itself. This is used when creating
    # redirection URLs. In the context of virtual hosts, the ServerName
    # specifies what hostname must appear in the request's Host: header to
    # match this virtual host. For the default virtual host (this file) this
    # value is not decisive as it is used as a last resort host regardless.
    # However, you must set it for any further virtual host explicitly.
    ServerName ask81083637.publicvm.com
    ServerAlias www.ask81083637.publicvm.com
    Redirect permanent / https://ask81083637.publicvm.com
    ServerAdmin webmaster@localhost
    DocumentRoot /var/www/html

    # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
```

Εικόνα 10.

-Έπειτα πάμε στο αρχείο `/etc/apache2/sites-enabled/default-ssl.conf` και βάζουμε το `ServerName ask81083637.publicvm.com:`

```
GNU nano 5.4 /etc/apache2/sites-enabled/default-ssl.conf
<IfModule mod_ssl.c>
    <VirtualHost _default_:443>
        ServerName ask81083637.publicvm.com
        ServerAdmin webmaster@localhost

        DocumentRoot /var/www/html
```

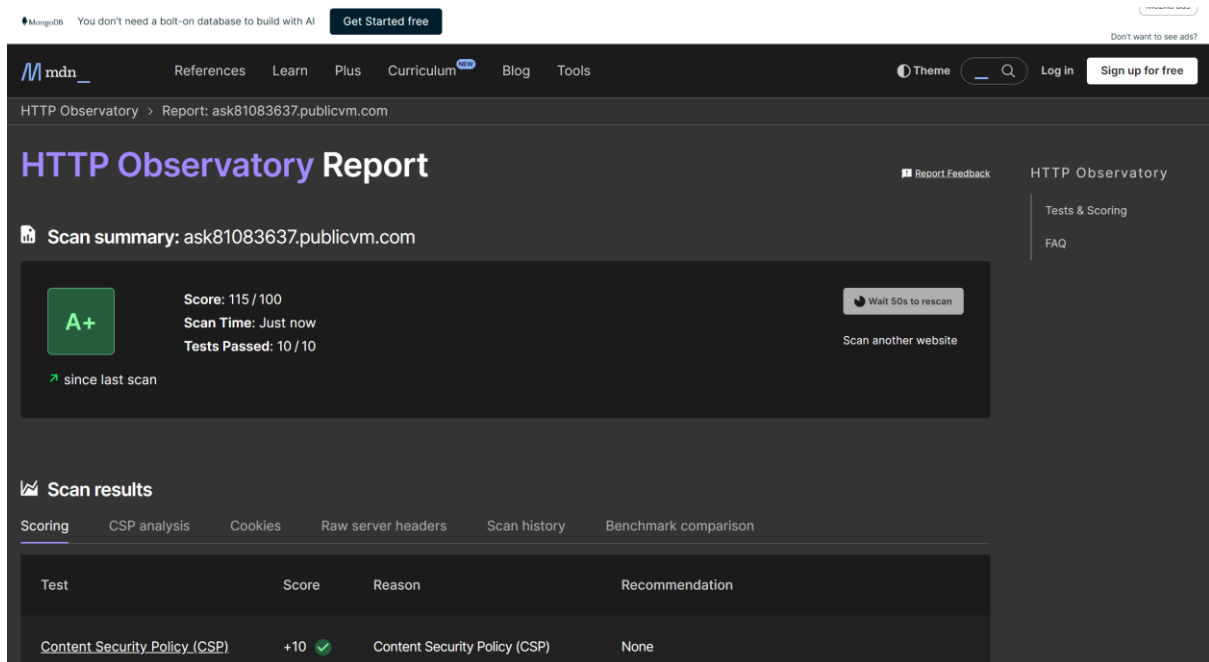
Εικόνα 11.

-Τέλος, στο αρχείο `/etc/apache2/apache2.conf` βάζουμε τα παρακάτω headers:

```
# vim: syntax=apache ts=4 sw=4 sts=4 sr noet
<IfModule mod_headers.c>
    #Mozilla observatory site
    Header set Content-Security-Policy "frame-ancestors 'none';"
    Header set Content-Security-Policy "default-src 'none';"
    Header always set X-Frame-Options "DENY"
    Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains; preload"
```

Εικόνα 12.

Έχοντας κάνει τα παραπάνω, κάνουμε rescan την σελίδα μας και βλέπουμε τα αποτελέσματα:



Εικόνα 13.

2. Για να υποστηρίξει, το site, μόνο TLSv1.3 πρωτόκολλα και τα recommended cipher suites του TLSv1.2, πρέπει αρχικά να στο αρχείο /etc/apach2/mods-enabled/ssl.conf και να προσθέσουμε τις παρακάτω γραμμές:

```
# SSL server cipher order preference:
# Use server priorities for cipher algorithm choice.
# Clients may prefer lower grade encryption. You should enable this
# option if you want to enforce stronger encryption, and can afford
# the CPU cost, and did not override SSLCipherSuite in a way that puts
# insecure ciphers first.
# Default: Off
SSLProtocol all TLSv1.3
SSLProtocol TLSv1.2
SSLCipherSuite AEAD-AES128-GCM-SHA256:AEAD-AES256-GCM-SHA384:AEAD-CHACHA20-POLY1305-SHA256:ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-ECDSA-CHACHA20-POLY1305-SHA256:
SSLHonorCipherOrder on

# The protocols to enable.
```

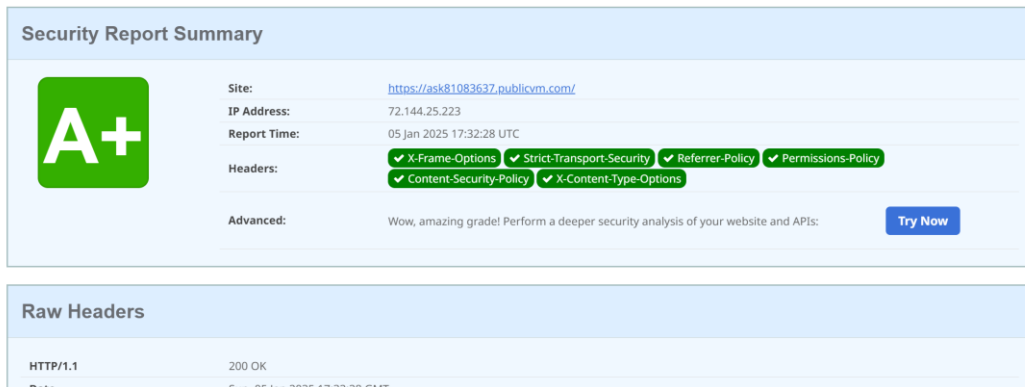
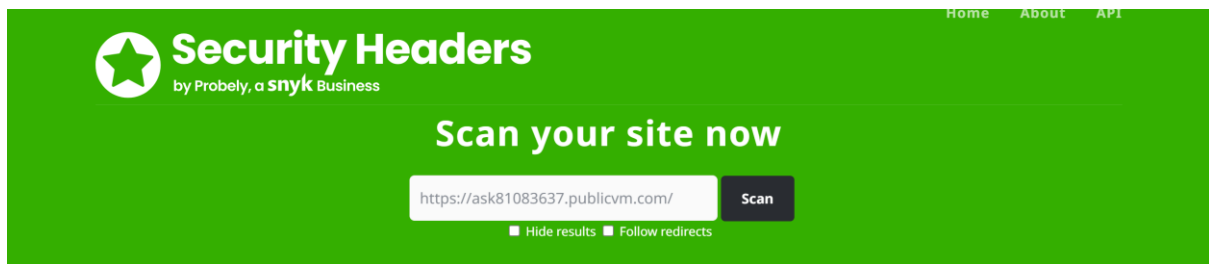
Εικόνα 14.

3. Για να μεγιστοποιήσουμε την προστασία των HTTP επικεφαλίδων, που ελέγχουμε με την χρήση του <https://securityheaders.com/>, έχει απομείνει ένα πράγμα να κάνουμε για να πάρουμε την καλύτερη βαθμολογία. Πάμε πάλι στο αρχείο /etc/apache2/apache2.conf και εκεί που βάλαμε τα headers για να μεγιστοποιήσουμε την προστασία μέσω mozilla observatory, βάζουμε και τα παρακάτω headers:

```
#security headers site
Header always set Referrer-Policy "strict-origin-when-cross-origin"
Header always set Permissions-Policy "geolocation=(), camera=(), microphone=(), payment=()"
Header set X-Content-Type-Options "nosniff"
</IfModule>
```

Εικόνα 15.

Και τρέχοντας το τεστ βλέπουμε ότι παίρνουμε άριστο σκορ:



Εικόνα 16.

4. Τέλος, για το τεστ του πιστοποιητικού μέσω του <https://www.ssllabs.com/ssltest/>, παρατηρούμε ότι υπάρχουν Chain issues. Για να το φτιάξουμε αυτό, πρέπει στο αρχείο `/etc/apache2/sites-enabled/default-ssl.conf` να βγάλουμε από τα σχόλια το `SSLCertificateChainFile`:

```
# Point SSLCertificateChainFile at a file containing the
# concatenation of PEM encoded CA certificates which form the
# certificate chain for the server certificate. Alternatively
# the referenced file can be the same as SSLCertificateFile
# when the CA certificates are directly appended to the server
# certificate for convinience.
SSLCertificateChainFile /etc/apache2/ssl.crt/server-ca.crt
```

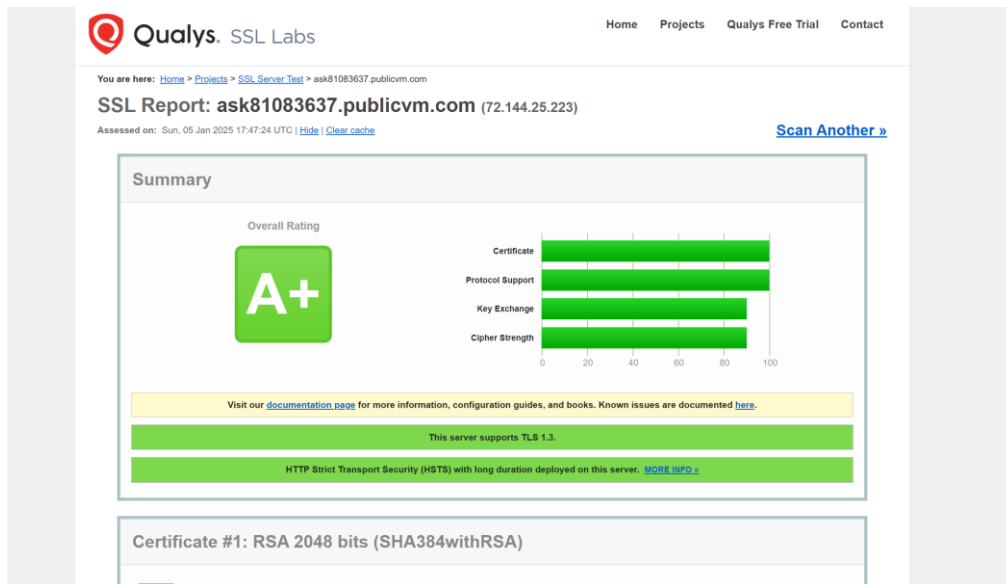
Εικόνα 17.

Εκεί, βλέπουμε το αρχείο που πρέπει να δημιουργήσουμε και να βάλουμε τα πιστοποιητικά intermediate CA που πήραμε από το Let's Encrypt. Άρα:

-Δημιουργούμε το directory: `sudo mkdir /etc/apache2/ssl.crt`

-Δημιουργούμε το αρχείο: `sudo nano /etc/apache2/ssl.crt/server-ca.crt` και βάζουμε τα intermediate CA πιστοποιητικά μέσα

Μετά, τρέχουμε το τεστ και βλέπουμε τα αποτελέσματα:



Εικόνα 18.

**Δυστυχώς, το <https://cryptcheck.fr/> δεν μπορούσε να δουλέψει. Έλεγε ότι δεν υποστήριζε TLS ενώ όπως βλέπετε στο τέλος, το TLS υπήρχε και η σελίδα το υποστήριζε, αλλά δεν μπορούσε να το βρει το cryptcheck. Συν ότι λόγω των περιορισμών που έχει δεν είχα την δυνατότητα να κάνω πολύ debugging.